Studio Nx

Backend(FastAPI/Python) 44 — check_current_password()

2026-10-12

Backend(FastAPI/Python) 44 — `check_current_password()`

항목	내용
파일	`studionx/backend/app/services/user_service.py`
작업	P1-09 비밀번호 변경·탈퇴: 비밀번호 재확인 (PRD 01 FR-107, FR-108)
작성	Claude (AI), 2026-10-07, 사용자 검토
이전 · 다음	43 `GET /profile-images/{name}` · 45 `change_password()`

1. 하는 일

이미 로그인한 회원에게 비밀번호를 한 번 더 확인합니다. 맞으면 아무것도 하지 않고(`None`), 틀리면 400으로 응답합니다.

저장된 비밀번호 `Abcdef1!`에 넣은 값	결과
`Abcdef1!`	통과합니다 (`None`)
`Abcdef1?`, `abcdef1!`, `" Abcdef1!"`, 빈 문자열	400 `WRONG_PASSWORD` "Password is incorrect."
100자 (bcrypt 한도인 72바이트를 넘음)	똑같이 400입니다 (500이 아닙니다)
해시가 `"!"`인 경우 (보관 기간 정리를 거친 계정)	어떤 값이든 400입니다

2. 언제 쓰나

쓰는 곳	다시 묻는 이유
45번 `change_password`	"지금 비밀번호" 칸입니다. 잠깐 자리를 비운 사이에 다른 사람이 비밀번호를 바꾸지 못하게 합니다
46번 `withdraw`	탈퇴 창의 비밀번호 칸입니다 (FIX-01 `promptDialog`). 되돌릴 수 없는 일이기 때문입니다

로그인(29번 `authenticate`)과 다른 점

	29번 로그인	44번 재확인
회원	아직 모릅니다 (이메일로 찾습니다)	이미 압니다 (토큰의 회원)
틀렸을 때	401 `INVALID_CREDENTIALS`	**400** `WRONG_PASSWORD`
응답 시간 맞추기 (가짜 해시)	합니다. 없는 이메일인지 숨기기 위해서입니다	필요 없습니다. 숨길 것이 없기 때문입니다

3. 코드

import (파일 맨 위)

```
from app.core.errors import AppError, ErrorCode
from app.core.security import verify_password
```

`verify_password` **줄을 이번에 추가했습니다** (나머지 import는 P1-08 그대로입니다).

함수

```
def check_current_password(user: User, password: str) -> None:
    if not verify_password(password, user.password_hash):
        raise AppError(ErrorCode.WRONG_PASSWORD, 400, "Password is incorrect.")
```

문법 풀이

import 문법	뜻
`from app.core.security import verify_password`	P1-04(16)에서 만든 함수입니다. bcrypt로 비교하고, 오류가 나면 `False`를 돌려줍니다

식	뜻
`-> None`	돌려주는 값이 없습니다. "통과하면 조용히 끝나고, 아니면 오류를 낸다"는 검사 함수입니다
`if not …: raise …`	틀렸을 때만 멈춥니다

4. 흐름

1. 넣은 비밀번호를 저장된 해시와 비교합니다.
2. 틀리면 400으로 응답하고, 맞으면 그대로 끝납니다.

5. 왜 이렇게

선택	이유
401이 아니라 **400**으로 응답	화면의 `api.js`(P1-02 02)는 401을 받으면 "토큰이 만료되었다"고 판단해서 재발급을 시도하고, 그래도 401이면 로그인 화면으로 보냅니다. 비밀번호를 잘못 입력했을 뿐인데 **로그아웃되면 안 됩니다**
별도 코드 `WRONG_PASSWORD`	화면이 "Current password is incorrect."처럼 그 칸에 문구를 붙일 수 있게 합니다 (P1-10)
두 줄이지만 함수로 분리	45번과 46번이 같은 규칙을 씁니다. 문구와 코드가 한곳에 모입니다
DB를 다시 읽지 않음	06번 `CurrentUser`가 이미 최신 회원 정보를 읽어 왔기 때문입니다

알아 둘 점 (여러 번 틀리는 경우): 로그인한 사람이 이 창에서 비밀번호를 계속 바꿔 입력하며 맞혀 볼 수는 있습니다. 하지만 이미 그 계정으로 로그인한 상태라서 얻을 것이 적습니다. 횟수 제한은 로그인 반복 제한과 함께 나중에 검토합니다.

6. 시험 (`tests/test_user_service.py`에 7개를 추가해서 모두 63개)

시험	확인한 것
맞는 비밀번호	`None`을 돌려줍니다
틀린 경우 5가지	한 글자 다름, 대소문자 다름, 앞에 공백, 빈 문자열, 100자는 모두 400 `WRONG_PASSWORD` "Password is incorrect."입니다
해시 `"!"`	400입니다

전체 시험 321개가 통과했고, `ruff` 검사도 통과했습니다.